Lab 5: Static Code Analysis

BEFORE: Original Code and Analysis Reports

Name: Vinodkumar L

SRN: PES1UG25AM817

File: premium_calculator.py

Tools: Pylint, Bandit, Flake8

1. Results on the Original Code

Tool	Result
Pylint	5.73 / 10
Bandit	10 issues (1 High, 5 Medium, 4 Low)
Flake8	19 warnings

Running the program also showed bugs no tool flagged: quote 1 and quote 2 for the same customer differ (6000 vs 5500), a non-smoker passed as "no" is charged the smoker loading, a life quote comes out at -800, the age for a 31-12-1990 birth date prints 36 (should be 35), and a 29 February start date crashes the renewal calculation.

2. Issues Identified

2.1 Security (Bandit), High and Medium first

Issue	Type	Line(s)	Description	Fix Approach
Unsafe tar.extractall (B202, High)	Security	63–65	A customer-uploaded archive can contain ../../x or absolute paths and overwrite files outside claims_docs (path traversal).	tar.extractall("claims_docs", filter="data") (PEP 706), inside with tarfile.open(...). Tested: a ../escape.txt member is rejected.
TLS verification disabled (B323, Medium)	Security	58	ssl._create_unverified_context() accepts any certificate, so a man-in-the-middle can serve fake rate tables. Also a private API (Pylint W0212).	ssl.create_default_context().
urlopen accepts any scheme (B310, Medium)	Security	59	file:///etc/passwd or custom schemes could be passed in; no timeout, so it can hang forever.	Allow only https, add timeout=10, use with. # nosec B310 kept with a comment explaining the scheme check.

Issue	Type	Line(s)	Description	Fix Approach
Untrusted XML parsed with stdlib (B314/B405, Medium)	Security	7, 48	xml.etree is vulnerable to entity-expansion ("billion laughs") on partner XML.	defusedxml.ElementTree; added requirements.txt. Tested: an entity payload raises EntitiesForbidden.
Bind to all interfaces (B104, Medium)	Security	12	HOST = "0.0.0.0" exposes the service on every network interface.	Default 127.0.0.1, overridable with PREMIUM_HOST.
Log file in /tmp (B108, Medium)	Security	14	World-writable directory; another user can pre-create or symlink the log.	Default to premium_quotes.log in the working dir; override with PREMIUM_LOG_FILE.
Hardcoded secret (B105, Low)	Security	13	Underwriter token is in source control (and was repeated in main()).	Read from UNDERWRITER_TOKEN env var; empty means nobody is authorised; removed from main().
Non-constant-time token check	Security	74	== can leak the token through timing.	hmac.compare_digest.
random for policy numbers (B311, Low)	Security	37	Predictable numbers can be guessed.	secrets.randbelow. Also: save_quote now retries on collision (previously a clash silently overwrote another quote).
Bare except + continue (B112, Low; E722; W0702)	Bug / Security	53–54	Swallows every error (even KeyboardInterrupt) with no trace.	Catch (TypeError, ValueError) and logging.warning the bad element. Also reject unknown types and negative values.

2.2 Logic bugs not flagged by tools

Issue	Type	Line(s)	Description	Fix Approach
Mutable default arg + mutation	Bug	17, 27	discounts=[] is shared across calls and append(500) runs every call, so identical customers get different quotes (6000 vs 5500, and later quotes keep shrinking).	Default None; never mutate the caller's list; the stray append(500) is removed. Quotes 1 and 2 now match (6000.0).

Issue	Type	Line(s)	Description	Fix Approach
smoker="no" treated as smoker	Bug	92	A non-empty string is truthy, so the 1.3× loading applied to a non-smoker.	Applicant dataclass validates smoker is a real bool (raises TypeError). Also cuts the argument count 6 → 4.
Negative premium	Bug	25–26	Stacked discounts gave -800.0.	Negative inputs rejected; result floored at 0 and rounded to 2 decimals. *Assumption:* a floor of zero (the business may prefer a minimum premium).
Wrong age	Bug	33	year - year ignores the birthday (printed 36 for a DOB of 31-12-1990 on 26-10-2026; correct is 35).	Compare (month, day); reject future dates; today parameter for testing.
29 Feb renewal crash	Bug	81	date.replace(year=...) raises ValueError for 2024-02-29 + 1 year.	Fall back to 28 Feb.
Instalment loses money, months=0	Bug	67–71	floor drops paise (12 × 664 < 7970); months == 0 quietly returned the full premium.	round(premium / months, 2); months <= 0 raises ValueError.
Unknown policy type	Bug	18	BASE_RATES[...] raised a bare KeyError.	Explicit ValueError message.
Log line breaks on commas	Bug	43	Name Smith, John corrupts the CSV log.	csv.writer handles quoting.
main() ran on import	Design	107	Importing the module executed the demo.	if __name__ == "__main__": guard.

2.3 Code quality (Pylint)

Issue	Type	Line(s)	Description	Fix Approach
Missing docstrings (C0114, C0116)	Style	1, 17, 30 … 89	13 missing.	Module and function docstrings.
Non-snake_case names (C0103)	Style	11 functions	e.g. calculatePremium.	Renamed (calculate_premium, age_from_dob, …).

Issue	Type	Line(s)	Description	Fix Approach
Too many arguments (R0913, R0917)	Design	17	6 parameters.	Applicant dataclass.
open() without with / encoding (R1732, W1514)	Resource	42–44	File leaks if write raises.	with open(..., encoding="utf-8").
Smaller items (C0209, R1705, R1703, C0200, C0301)	Style	43, 68, 74, 86, 101	f-string, redundant else, range(len()), 148-char line.	f-string, early return, enumerate, wrapped line.

2.4 Style (Flake8)

Issue	Type	Line(s)	Description	Fix Approach
E302 / E305 (12 warnings)	Style	17–107	Needed 2 blank lines around top-level definitions.	Added.
E501 line too long (5 warnings)	Style	14, 17, 52, 87, 101	Over 79 characters.	Wrapped.
E722 bare except	Style	53	See above.	See above.

3. Reports on the Original Code

Pylint

```
************* Module premium_calculator
premium_calculator.py:101:0: C0301: Line too long (148/100) (line-
too-long)
premium_calculator.py:1:0: C0114: Missing module docstring (missing-
module-docstring)
premium_calculator.py:17:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:17:0: C0103: Function name "calculatePremium"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:17:0: W0102: Dangerous default value [] as
argument (dangerous-default-value)
premium_calculator.py:17:0: R0913: Too many arguments (6/5) (too-
many-arguments)
premium_calculator.py:17:0: R0917: Too many positional arguments
(6/5) (too-many-positional-arguments)
premium_calculator.py:30:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:30:0: C0103: Function name "ageFromDob"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:36:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:36:0: C0103: Function name "policyNumber"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:39:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:39:0: C0103: Function name "saveQuote" doesn't
conform to snake_case naming style (invalid-name)
premium_calculator.py:42:8: W1514: Using open without explicitly
specifying an encoding (unspecified-encoding)
premium_calculator.py:43:12: C0209: Formatting a regular string
which could be an f-string (consider-using-f-string)
premium_calculator.py:42:8: R1732: Consider using 'with' for
resource-allocating operations (consider-using-with)
premium_calculator.py:47:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:47:0: C0103: Function name "importPolicies"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:53:8: W0702: No exception type(s) specified
(bare-except)
premium_calculator.py:57:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:57:0: C0103: Function name "fetchRates"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:58:10: W0212: Access to a protected member
_create_unverified_context of a client class (protected-access)
premium_calculator.py:61:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:61:0: C0103: Function name
"importClaimDocuments" doesn't conform to snake_case naming style
(invalid-name)
```

```
premium_calculator.py:63:10: R1732: Consider using 'with' for
resource-allocating operations (consider-using-with)
premium_calculator.py:67:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:67:0: C0103: Function name "monthlyInstalment"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:68:4: R1705: Unnecessary "else" after
"return", remove the "else" and de-indent the code inside it (no-
else-return)
premium_calculator.py:73:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:73:0: C0103: Function name "isAuthorised"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:74:4: R1703: The if statement can be replaced
with 'return bool(test)' (simplifiable-if-statement)
premium_calculator.py:74:4: R1705: Unnecessary "else" after
"return", remove the "else" and de-indent the code inside it (no-
else-return)
premium_calculator.py:79:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:79:0: C0103: Function name "renewalDue"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:83:0: C0116: Missing function or method
docstring (missing-function-docstring)
premium_calculator.py:83:0: C0103: Function name "printQuotes"
doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:86:4: C0200: Consider using enumerate instead
of iterating with range and len (consider-using-enumerate)
premium_calculator.py:89:0: C0116: Missing function or method
docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 5.73/10
```

Bandit

```
[main]    INFO  profile include tests: None
[main]    INFO  profile exclude tests: None
[main]    INFO  cli include tests: None
[main]    INFO  cli exclude tests: None
[main]    INFO  running on Python 3.12.3
Run started:2026-10-26 07:59:03.446715+00:00

Test results:
>> Issue: [B405:blacklist] Using xml.etree.ElementTree to parse
untrusted XML data is known to be vulnerable to XML attacks. Replace
xml.etree.ElementTree with the equivalent defusedxml package, or
make sure defusedxml.defuse_stdlib() is called.
   Severity: Low   Confidence: High
   CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.
html#b405-import-xml-etree
   Location: ./premium_calculator.py:7:0
```

```
6     import urllib.request
7     import xml.etree.ElementTree as ET
8     from datetime import datetime

--------------------------------------------------
>> Issue: [B104:hardcoded_bind_all_interfaces] Possible binding to
all interfaces.
   Severity: Medium   Confidence: Medium
   CWE: CWE-605 (https://cwe.mitre.org/data/definitions/605.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b104_hardcoded_bind_a
ll_interfaces.html
   Location: ./premium_calculator.py:12:7
11    quotes = {}
12    HOST = "0.0.0.0"
13    UNDERWRITER_TOKEN = "uw-7f3a9c2e1b"

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded
password: 'uw-7f3a9c2e1b'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_passwo
rd_string.html
   Location: ./premium_calculator.py:13:20
12    HOST = "0.0.0.0"
13    UNDERWRITER_TOKEN = "uw-7f3a9c2e1b"
14    LOG_FILE = "/tmp/premium_quotes.log" if os.name != "nt" else
"premium_quotes.log"

--------------------------------------------------
>> Issue: [B108:hardcoded_tmp_directory] Probable insecure usage of
temp file/directory.
   Severity: Medium   Confidence: Medium
   CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b108_hardcoded_tmp_di
rectory.html
   Location: ./premium_calculator.py:14:11
13    UNDERWRITER_TOKEN = "uw-7f3a9c2e1b"
14    LOG_FILE = "/tmp/premium_quotes.log" if os.name != "nt" else
"premium_quotes.log"
15    BASE_RATES = {"health": 5000, "motor": 3000, "life": 8000}

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not
suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.ht
ml#b311-random
   Location: ./premium_calculator.py:37:24
36    def policyNumber():
```

```
37        return "POL-" + str(random.randint(100000, 999999))
38

--------------------------------------------------
>> Issue: [B314:blacklist] Using xml.etree.ElementTree.fromstring to
parse untrusted XML data is known to be vulnerable to XML attacks.
Replace xml.etree.ElementTree.fromstring with its defusedxml
equivalent function or make sure defusedxml.defuse_stdlib() is
called
   Severity: Medium   Confidence: High
   CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.ht
ml#b313-b320-xml-bad-elementtree
   Location: ./premium_calculator.py:48:11
47    def importPolicies(xml_text):
48        root = ET.fromstring(xml_text)
49        result = []

--------------------------------------------------
>> Issue: [B112:try_except_continue] Try, Except, Continue detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b112_try_except_conti
nue.html
   Location: ./premium_calculator.py:53:8
52                result.append((p.get("type"), int(p.get("age")),
int(p.get("sum"))))
53            except:
54                continue
55        return result

--------------------------------------------------
>> Issue: [B323:blacklist] By default, Python will create a secure,
verified ssl context for use in such classes as HTTPSConnection.
However, it still allows using an insecure context via the
_create_unverified_context that  reverts to the previous behavior
that does not validate certificates or perform hostname checks.
   Severity: Medium   Confidence: High
   CWE: CWE-295 (https://cwe.mitre.org/data/definitions/295.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.ht
ml#b323-unverified-context
   Location: ./premium_calculator.py:58:10
57    def fetchRates(url):
58        ctx = ssl._create_unverified_context()
59        return urllib.request.urlopen(url, context=ctx).read()

--------------------------------------------------
>> Issue: [B310:blacklist] Audit url open for permitted schemes.
Allowing use of file:/ or custom schemes is often unexpected.
   Severity: Medium   Confidence: High
   CWE: CWE-22 (https://cwe.mitre.org/data/definitions/22.html)
```

```
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.ht
ml#b310-urllib-urlopen
   Location: ./premium_calculator.py:59:11
58        ctx = ssl._create_unverified_context()
59        return urllib.request.urlopen(url, context=ctx).read()
60

--------------------------------------------------
>> Issue: [B202:tarfile_unsafe_members] tarfile.extractall used
without any validation. Please check and discard dangerous members.
   Severity: High   Confidence: High
   CWE: CWE-22 (https://cwe.mitre.org/data/definitions/22.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b202_tarfile_unsafe_m
embers.html
   Location: ./premium_calculator.py:64:4
63        tar = tarfile.open(archive_path)
64        tar.extractall("claims_docs")
65        tar.close()

--------------------------------------------------

Code scanned:
      Total lines of code: 91
      Total lines skipped (#nosec): 0
      Total potential issues skipped due to specifically being
disabled (e.g., #nosec BXXX): 0

Run metrics:
      Total issues (by severity):
            Undefined: 0
            Low: 4
            Medium: 5
            High: 1
      Total issues (by confidence):
            Undefined: 0
            Low: 0
            Medium: 3
            High: 7
Files skipped (0):
```

Flake8

```
premium_calculator.py:14:80: E501 line too long (81 > 79 characters)
premium_calculator.py:17:1: E302 expected 2 blank lines, found 1
premium_calculator.py:17:80: E501 line too long (82 > 79 characters)
premium_calculator.py:30:1: E302 expected 2 blank lines, found 1
premium_calculator.py:36:1: E302 expected 2 blank lines, found 1
premium_calculator.py:39:1: E302 expected 2 blank lines, found 1
premium_calculator.py:47:1: E302 expected 2 blank lines, found 1
premium_calculator.py:52:80: E501 line too long (80 > 79 characters)
premium_calculator.py:53:9: E722 do not use bare 'except'
premium_calculator.py:57:1: E302 expected 2 blank lines, found 1
```

```
premium_calculator.py:61:1: E302 expected 2 blank lines, found 1
premium_calculator.py:67:1: E302 expected 2 blank lines, found 1
premium_calculator.py:73:1: E302 expected 2 blank lines, found 1
premium_calculator.py:79:1: E302 expected 2 blank lines, found 1
premium_calculator.py:83:1: E302 expected 2 blank lines, found 1
premium_calculator.py:87:80: E501 line too long (89 > 79 characters)
premium_calculator.py:89:1: E302 expected 2 blank lines, found 1
premium_calculator.py:101:80: E501 line too long (148 > 79
characters)
premium_calculator.py:107:1: E305 expected 2 blank lines after class
or function definition, found 1
```